VulnScan Pro

Security Assessment Report

Target URL: http://127.0.0.1:5001

Scan Date: 2026-03-29 09:14:42

Overall Score: 0/100 (Grade: F)

Executive Summary

Security score is 0/100. Found 3 critical vulnerabilities requiring immediate attention.

OWASP Mapping

OWASP Category	CWE	CVSS	Finding	Severity
A01:2021 - Broken Access Control				
	CWE-352	6.1	Cookie (SameSite)	LOW
A02:2021 - Cryptographic Failures				
	CWE-298	7.4	Invalid Cert	HIGH
A03:2021 - Injection				
	CWE-79	6.1	X-XSS-Protection	MEDIUM
	CWE-79	6.1	Vuln at http://127.0.0.1:5001/login	HIGH
	CWE-79	6.1	Vuln at http://127.0.0.1:5001/xss-stored	HIGH
A05:2021 - Security Misconfiguration				
	CWE-923	9.1	Port 6379 open	HIGH
	CWE-319	7.4	Strict-Transport-Security	HIGH
	CWE-923	7.3	Port 135 open	INFO
	CWE-923	7.3	Port 445 open	INFO
	CWE-923	7.3	Port 8000 open	INFO
	CWE-693	6.1	Content-Security-Policy	HIGH
	CWE-1021	6.1	X-Frame-Options	MEDIUM
	CWE-183	5.3	Missing SPF	MEDIUM
	CWE-693	4.3	X-Content-Type-Options	MEDIUM
A06:2021 - Vulnerable and Outdated Components				
	CWE-1035	10.0	Vulnerable component jquery 1.12.4	HIGH
	CWE-1104	7.5	Referrer-Policy	LOW
	CWE-1104	7.5	Permissions-Policy	LOW
	CWE-1104	7.5	Cache-Control	INFO
	CWE-1104	7.5	Cookie (tracking_id)	MEDIUM
	CWE-1104	7.5	Vuln at http://127.0.0.1:5001/vulnerable-form	HIGH
	CWE-1104	7.5	Vuln at http://127.0.0.1:5001/csrf	HIGH
	CWE-1104	7.5	Vuln at http://127.0.0.1:5001/login	HIGH
	CWE-1104	7.5	AWS Access Key ID found	CRITICAL
	CWE-1104	7.5	GitHub Personal Access Token found	CRITICAL
	CWE-1104	7.5	Hardcoded secret or password found	HIGH
	CWE-1104	7.5	Hardcoded secret or password found	HIGH

OWASP Category	CWE	CVSS	Finding	Severity
	CWE-1104	7.5	Internal IP address reference found	MEDIUM
	CWE-1104	7.5	Localhost reference found (dev config?)	LOW
	CWE-1104	7.5	Internal API endpoint path discovered	INFO
	CWE-1104	7.5	Developer comment flagging unresolved issue	INFO
	CWE-1104	7.5	Commented-out code containing sensitive keyword	MEDIUM
	CWE-1104	7.5	Commented-out code containing sensitive keyword	MEDIUM
	CWE-1104	7.5	Commented-out code containing sensitive keyword	MEDIUM

Port Scan

Finding	Severity	Description	Recommendation
Port 135 open	INFO	Service: MSRPC	
Port 445 open	INFO	Service: SMB	
Port 6379 open	HIGH	Service: Redis	Close port if not needed.
Port 8000 open	INFO	Service: HTTP-Alt	

Headers

Finding	Severity	Description	Recommendation
Content-Security-Policy	HIGH	Missing	Implement CSP to prevent XSS.
Strict-Transport-Security	HIGH	Missing	Enforce HTTPS connections using HSTS.
X-Frame-Options	MEDIUM	Missing	Prevent clickjacking by setting to DENY or
X-Content-Type-Options	MEDIUM	Missing	Set to nosniff to prevent MIME confusion a
X-XSS-Protection	MEDIUM	Missing	Enable browser built-in XSS protection (tho
Referrer-Policy	LOW	Missing	Control referrer information sent to other si
Permissions-Policy	LOW	Missing	Restrict access to browser features like ca
Cache-Control	INFO	Missing	Ensure sensitive pages are not cached.
Cookie (tracking_id)	MEDIUM	Missing	Add Secure, HttpOnly flag to cookie trackin
Cookie (SameSite)	LOW	Missing	Add SameSite attribute to cookies to prote

Ssl

Finding	Severity	Description	Recommendation
Invalid Cert	HIGH	Cert is expired or invalid	Renew cert

Dns

Finding	Severity	Description	Recommendation
Missing SPF	MEDIUM	No SPF record found	Add SPF record

Tech

Finding	Severity	Description	Recommendation
Vulnerable component jquery 1.12.4	HIGH	CVEs: CVE-2015-9251	Update component

Xss

Finding	Severity	Description	Recommendation
Vuln at http://127.0.0.1:5001/login	HIGH	Param username vulnerable to payload <script>alert(1)</script>	Sanitize input (XSS) and use prepared statemen
Vuln at http://127.0.0.1:5001/vulnerable	HIGH	Param query vulnerable to payload <script>alert(1)</script>	Sanitize input (XSS) and use prepared statemen
Vuln at http://127.0.0.1:5001/xss-stored	HIGH	Param name vulnerable to payload <script>alert(1)</script>	Sanitize input (XSS) and use prepared statemen
Vuln at http://127.0.0.1:5001/csrf	HIGH	Param action vulnerable to payload <script>alert(1)</script>	Sanitize input (XSS) and use prepared statemen

Sqli

Finding	Severity	Description	Recommendation
Vuln at http://127.0.0.1:5001/login	HIGH	Param username vulnerable to payload '; DROP TABLE users; --	Sanitize input (XSS) and use prepared statemen

Js Analysis

Finding	Severity	Description	Recommendation
AWS Access Key ID found	CRITICAL	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: AWS_ACCESS_KEY_ID = 'AKIA...	Move secrets to server-side environment v
GitHub Personal Access Token found	CRITICAL	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: GITHUB_TOKEN = 'ghp_...	Move secrets to server-side environment v
Hardcoded secret or password found	HIGH	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: password = 'admin123'	Move secrets to server-side environment v
Hardcoded secret or password found	HIGH	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: password = 'admin123'	Move secrets to server-side environment v
Internal IP address reference found	MEDIUM	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: 192.168.1.100	Remove internal IP references from client-s
Localhost reference found (dev config?)	LOW	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: http://localhost:3	Remove localhost references from client-s
Internal API endpoint path discovered	INFO	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: /api/v1/internal/	Review exposed internal API endpoints
Developer comment flagging unresolved issue	INFO	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: // TODO: fix SQ	Remove developer comments before deployi
Commented-out code containing sensitive keyword	MEDIUM	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: // password = 'S	Remove commented-out code before deployi
Commented-out code containing sensitive keyword	MEDIUM	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: // hardcoded-s	Remove commented-out code before deployi
Commented-out code containing sensitive keyword	MEDIUM	Found in JS file: http://127.0.0.1:5001/static/js/secrets.js Evidence: // TODO: fix SQ	Remove commented-out code before deployi

Remediation Checklist

Follow these recommendations to improve your security posture:

• Close port if not needed.

• Implement CSP to prevent XSS.

• Enforce HTTPS connections using HSTS.

• Renew cert

• Update component

• Sanitize inputs and use prepared statements.

• Immediately rotate this AWS key. Use IAM roles or environment variables instead of hardcoding credentials.

• Revoke this token immediately at github.com/settings/tokens. Use CI/CD secrets management.

• Move secrets to server-side environment variables. Never include credentials in JavaScript.